soken

Smart contract security review

Arvo Protocol

Commit `ca8b3d2`, Robinhood testnet (46630)

21 October 2026

0	0	1	5	13
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

PREPARED BY SOKEN LTD	CLIENT Arvo Protocol, github.com/arvoprotocol
REPOSITORY AND COMMIT github.com/arvoprotocol/arvo-contracts, ca8b3d2	NETWORK Robinhood testnet (46630)
SCOPE An upgradeable staking core, its acquisition escrow, two libraries, the shared types and the oracle interface	FINDINGS 0 Critical, 0 High, 1 Medium, 5 Low, 13 Informational
CURRENT CODE Contracts `007754e6`, app `9e9ce9b`; tests, bytecode and roles read 2026-10-21	DATE 21 October 2026

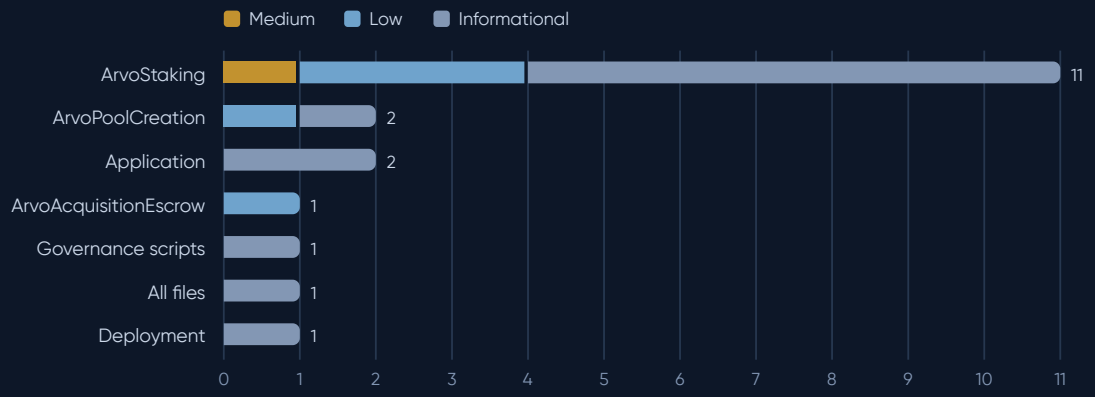
01 Summary

0	0	1	5	13
CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL

6	1,581	253
SOURCE FILES IN SCOPE	LINES OF CODE IN SCOPE	TESTS RUN, 0 FAILED

13	2,600,000	24,436 / 24,576
INVARIANT CAMPAIGNS, 0 VIOLATIONS	INVARIANT CALLS	IMPLEMENTATION RUNTIME BYTES

Figure 1. Findings by component



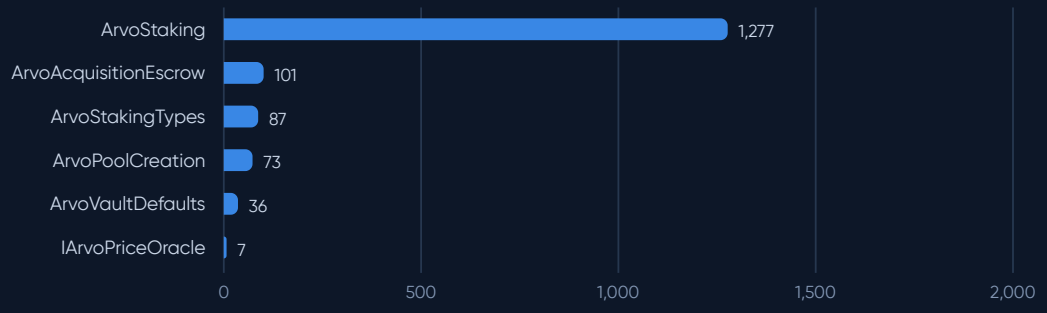
ID	TITLE	COMPONENT	SEVERITY
M-001	ARVO principal is locked during emergency exit of a DUAL acquisition position when the escrow is illiquid	ArvoStaking	MEDIUM
L-001	Divide before multiply loses precision in `_crossReward`	ArvoStaking	LOW
L-002	Custom pools allow a zero minimum stake amount	ArvoPoolCreation	LOW
L-003	Critical escrow state changes emit no events	ArvoAcquisitionEscrow	LOW
L-004	Unpausing waits the timelock delay after the governance handoff	ArvoStaking	LOW
L-005	`isUsdcSolvent` reports false insolvency once an acquisition reward limit is set	ArvoStaking	LOW
I-001	Storage layout is append-only and upgrade compatible	ArvoStaking	INFORMATIONAL
I-002	Non-upgradeable reentrancy guard depends on cancun transient storage	ArvoStaking	INFORMATIONAL
I-003	Governance scripts implement a correct two-stage handoff	Governance scripts	INFORMATIONAL
I-004	Floating Solidity pragma	All files	INFORMATIONAL
I-005	Unused error declarations in `ArvoPoolCreation`	ArvoPoolCreation	INFORMATIONAL

I-006	Irreversible acquisition escrow binding	ArvoStaking	INFORMATIONAL
I-007	Centralization risk mitigated by the timelock and the multisig	ArvoStaking	INFORMATIONAL
I-008	The user position array grows without bound	ArvoStaking	INFORMATIONAL
I-009	The static analysis locks-Ether flag is a false positive	ArvoStaking	INFORMATIONAL
I-010	Implementation runtime sits 140 bytes below the EIP-170 limit	ArvoStaking	INFORMATIONAL
I-011	Live testnet holds all five roles on a single externally owned account	Deployment	INFORMATIONAL
I-012	Offline auth test suite needs dependencies and a fixture to run	Application	INFORMATIONAL
I-013	Admin login challenge uses a custom message format rather than EIP-4361	Application	INFORMATIONAL

02 Scope

CONTRACT	FILE	SLOC	TYPE
ArvoStaking	`src/ArvoStaking.sol`	1,277	Upgradeable staking core, UUPS
ArvoAcquisitionEscrow	`src/ArvoAcquisitionEscrow.sol`	101	USDC principal custody per acquisition pool
ArvoStakingTypes	`src/ArvoStakingTypes.sol`	87	Structs and enums
ArvoPoolCreation	`src/ArvoPoolCreation.sol`	73	Vault creation and validation library
ArvoVaultDefaults	`src/ArvoVaultDefaults.sol`	36	Default vault parameters library
IArvoPriceOracle	`src/interfaces/IArvoPriceOracle.sol`	7	Oracle interface
Total		**1,581**	

Figure 2. Size of the code in scope, source lines without comments and blank lines

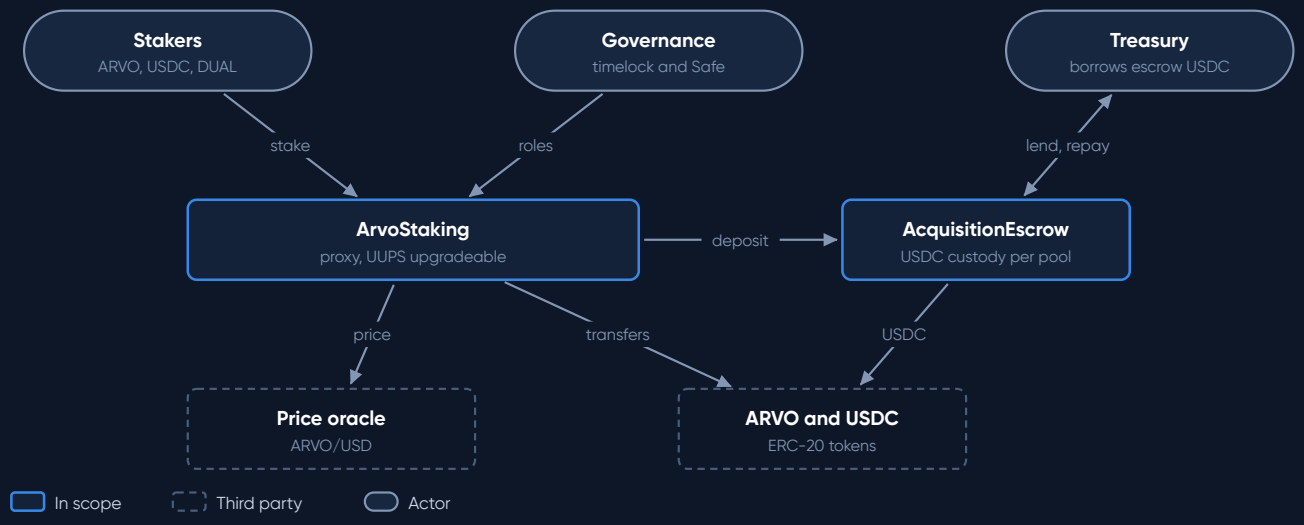


Out of scope

ITEM	REASON
Baseline and mock contracts (`ArvoStakingBaseline`, `MockToken`, testnet fixtures)	Compatibility and test fixtures, not part of the deployed set
`arvo-app` full application and API penetration test, commit `e6ab45a`	A separate engagement. The bounded fund-safety surface of the app (transaction construction, treasury and reward-funding controls, admin and wallet authentication) was reviewed here, see Application fund-safety review.
`lib/` (OpenZeppelin upgradeable and non-upgradeable)	Third-party code. Reviewed only for how the contracts use it
The price oracle contract behind `IArvoPriceOracle`	External. Only the interface is in scope
USDC and ARVO token contracts	External tokens
The acquisition treasury	External actor that borrows and repays escrow principal

03 Architecture and privileged roles

Figure 3. Contracts in scope and their external dependencies



Privileged roles

ROLE	HOLDER ON CHAIN	TYPE	POWER
DEFAULT_ADMIN_ROLE	`0x4bfd52101d1ff4647477d1a48a9b9b0e9c74ed22`	Timelock	Grants and revokes roles, configures the oracle, the acquisition escrow and acquisition pools, and unpauses
UPGRADER_ROLE	`0x4bfd52101d1ff4647477d1a48a9b9b0e9c74ed22`	Timelock	Authorizes contract upgrades through `_authorizeUpgrade`
VAULT_MANAGER_ROLE	`0xc2Ba67d2A9A6E3dB6e54c58B1de62f33E11F5d7C`	Safe 2 of 2	Creates standard, custom and product pools, sets pool visibility and enablement, increases the protocol allocation, finalizes pools
REWARD_MANAGER_ROLE	`0xc2Ba67d2A9A6E3dB6e54c58B1de62f33E11F5d7C`	Safe 2 of 2	Funds rewards, reserves budgets, withdraws surplus and adds acquisition reward limits
PAUSER_ROLE	`0x64B5366B22B302AeB129c33cf52b5A1d5ccb2f58`	EOA	Pauses new stakes, restakes and compounds. Claims for matured positions stay open

OBSERVATION	DETAIL
Live holders	Read at block 140,005,118 on 2026-10-21: `DEFAULT_ADMIN_ROLE` and `UPGRADER_ROLE` on the timelock, `VAULT_MANAGER_ROLE` and `REWARD_MANAGER_ROLE` on the governance Safe, `PAUSER_ROLE` on the emergency authority. The deployer 0x8A382ca8B4536b924C5d1cb77A048f44396C1477 holds none of the five roles. A replay of all nineteen `RoleGranted` and `RoleRevoked` events since the creation block 129,954,977 gives the same five holders. The address `0x8d2fba76...ae5bb`, an externally owned account, holds none.
Timelock	`TimelockController` at 0x4bfd52101d1ff4647477d1a48a9b9b0e9c74ed22, minimum delay 86,400 seconds. Proposer, executor and canceller: the governance Safe only. The zero address holds no timelock role, so execution is not permissionless. The timelock is its own admin. One operation has passed through it: scheduled 2026-10-19 13:11:01 UTC, executed 2026-10-20 13:43:32 UTC.
Governance Safe	0xc2Ba67d2A9A6E3dB6e54c58B1de62f33E11F5d7C: Safe 1.4.1 on the canonical singleton `0x41675C09...7461a`, two owners, threshold 2, nonce 4. The two owners are externally owned accounts: the deployer key and the emergency authority key. A compromise of both keys gives vault and reward management at once and, through the timelock after 24 hours, administration and upgrades.
Transactions	The role grants, the timelock operation and the deployer renouncements are listed with block numbers and times in section 06.
Scope of privilege	No privileged function can move staker principal or committed rewards. Surplus withdrawal is bounded by the free capacity reported by `availableArvoRewardCapacity` and `availableUsdcRewardCapacity`.

04 Method and severity scale

STEP	WORK DONE
Area review	Line-by-line reading of every in-scope file: the staking core with its accounting and solvency paths, the acquisition escrow custody, the pool-creation and defaults libraries, the shared types and the oracle interface
Cross-area review	Reward against principal segregation across pools; the staking lifecycle of stake, claim, emergency exit, restake and compound; cross-asset reward pricing and oracle staleness; access control mapped from every privileged function to its role
Testing	The existing suite built and run on a clean build; ten invariant campaigns and two proof-of-concept tests added for the material findings
Static analysis	Slither and Aderyn, used as leads only. No tool output is reported as a finding
Build verification	The build of `ca8b3d2` compared offline against the runtime size, the public ABI and the storage layout of the reviewed testnet build
Governance scripts	The two-stage handoff scripts read for role staging, verification and the final renouncement of the deployment account

Severity scale

SEVERITY	MEANING
CRITICAL	Loss or permanent freeze of staker funds with no unusual precondition
HIGH	Loss or freeze under realistic preconditions
MEDIUM	Limited loss, or loss that needs an uncommon but plausible condition inside the protocol's control
LOW	Limited loss that needs a failure outside the protocol, or a departure from the specification with a bounded effect
INFORMATIONAL	Documentation, hardening and integration notes

05 Findings

Medium

M-001 ARVO principal is locked during emergency exit of a DUAL acquisition position when the escrow is illiquid

MEDIUM

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:453–478`	Fund accessibility

DESCRIPTION

The emergency exit path settles a position through `_settleCashPosition`, which moves the ARVO principal held by the staking contract and the USDC principal held by the acquisition escrow in one transaction. For a DUAL position in an acquisition pool, if the escrow has lent its cash to the treasury through `releasePrincipal` and has not been repaid, the escrow `settle` call reverts with `LiquidityUnavailable` and rolls back the whole transaction, including the ARVO transfer that would have succeeded on its own.

STEP	EFFECT
Stake DUAL, 100,000 ARVO and 1,000 USDC, into an acquisition pool	Principal recorded in the staking contract and in the escrow
Treasury calls `releasePrincipal` for the 1,000 USDC	Escrow cash drops to zero
Protocol paused, staker calls `emergencyExit`	The ARVO transfer at line 473 would succeed on its own
`_settleAcquisition` calls `escrow.settle`	Reverts with `LiquidityUnavailable`, so the ARVO transfer is rolled back

IMPACT

The ARVO principal, which is physically present in the staking contract and needs no escrow liquidity, stays locked until the treasury repays the escrow or the position matures for a normal claim, which carries the same escrow dependency. The duration is set by treasury repayment timing, outside the staker's control. For a FOUNDATION vault of 365 days the window is the full term. The effect is a temporary lockup, not a permanent loss.

DESIGN CONTEXT

The protocol blocks emergency exit of an acquisition position until its USDC principal is returned to the escrow, a block asserted by the test `testEmergencyExitRequiresReturnedPrincipalButForfeitsReward`. For the USDC leg that block is unavoidable, since the USDC was lent to the treasury. The finding is narrower: the custody-independent ARVO leg of a DUAL position is coupled to the same escrow-liquidity gate. The existing DUAL tests cover only the happy path. Whether all-or-nothing settlement is intended is a design decision for the protocol; if it is, the lockup becomes an accepted trade-off rather than a defect.

RECOMMENDATION

Decouple the ARVO settlement from the USDC escrow settlement in emergency exit: return the ARVO principal directly and record the USDC portion as a claim against the escrow that can be collected once liquidity is restored.

EVIDENCE

`SokenAuditPoC_.t.sol::testM001_DualEmergencyExitLocksArvoWhenEscrowReleased` stakes a DUAL position into an acquisition pool, releases the USDC principal to the treasury, pauses, and shows `emergencyExit` reverts with `LiquidityUnavailable` while the ARVO sits in the contract; the staker recovers it only after an

unrelated treasury `repay`. The test passes.

Low

L-001 Divide before multiply loses precision in `_crossReward`

LOW

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:1024-1029`	Arithmetic precision

DESCRIPTION

`_crossReward` divides before it multiplies: it computes an intermediate value as `(amount * price) / (10 ** (uint256(decimals) + 12))` and then `reward = (value * rate) / BPS`. The first division truncates fractional USDC units before the reward rate is applied, losing up to one USDC micro-unit, 0.000001 USD, per position.

IMPACT

Negligible per position and at most one micro-unit. The rounding is systematic in favour of the protocol over the staker. With the 150,000 ARVO cross-minimum and the oracle configurations in use the loss is below one cent.

RECOMMENDATION

Combine into a single division, `reward = (amount * price * rate) / (10 ** (uint256(decimals) + 12) * BPS)`, and confirm that no intermediate value overflows at the maximum amount, price and rate.

L-002 Custom pools allow a zero minimum stake amount

LOW

COMPONENT	LOCATION	CATEGORY
ArvoPoolCreation	`src/ArvoPoolCreation.sol:72-76`	Input validation

DESCRIPTION

The `validate` function for custom vault configurations, factory type 1 through `createCustomPool`, does not require `minArvo` or `minUsdc` to be above zero when the matching stake modes are enabled. Product pools, factory type 2, enforce non-zero minimums at lines 55 and 56. A custom pool can therefore accept a one wei ARVO stake.

IMPACT

An administrator misconfiguration could allow dust stakes that consume pool reward budget and create storage entries with negligible principal. Each dust position still costs the staker a separate transaction, which limits practical abuse.

RECOMMENDATION

Add the same non-zero checks to `validate`: revert `InvalidConfiguration` when an ARVO or DUAL mode is enabled with `minArvo` of zero, and when a USDC or DUAL mode is enabled with `minUsdc` of zero.

L-003 Critical escrow state changes emit no events

LOW

COMPONENT	LOCATION	CATEGORY
ArvoAcquisitionEscrow	`src/ArvoAcquisitionEscrow.sol:53`, `:68`, `:101`, `:109`	Events

DESCRIPTION

Four state-changing functions in the acquisition escrow emit no events: `configure` sets the treasury and the opening time, `recordDeposit` increases cash, principal and the active-position count, `settle` decreases them and transfers USDC, and `finalize` marks a pool finalized. The `releasePrincipal`, `repay` and `withdrawExcess` functions do emit events.

IMPACT

Off-chain monitoring cannot track deposit flows, settlement activity or pool lifecycle transitions in the escrow, which hinders incident response and audit-trail reconstruction.

RECOMMENDATION

Emit an event from each state-changing function, at least `Deposited`, `Settled`, `Configured` and `Finalized`.

L-004 Unpausing waits the timelock delay after the governance handoff

LOW

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:1289`	Access control

DESCRIPTION

`unpause` requires `DEFAULT_ADMIN_ROLE`, which after the governance handoff is held by the timelock with a minimum 24 hour delay. A false-alarm pause cannot be reversed quickly. Claims for matured positions keep working during a pause, since `claim` carries no `whenNotPaused` modifier; new stakes, restakes and compounds are blocked.

IMPACT

A minimum 24 hour disruption of new staking activity follows an accidental pause. This is a deliberate trade-off that stops a compromised emergency authority from flipping pause and unpause.

RECOMMENDATION

If faster recovery is wanted, grant the governance Safe a dedicated unpauser role, or let the existing pauser role also unpause.

L-005 `isUsdcSolvent` reports false insolvency once an acquisition reward limit is set

LOW

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:1385–1389`, `:1369`, `:1173–1174`	Reporting accuracy

DESCRIPTION

`addAcquisitionRewardLimit` increments both `usdcRewardBudgetReserved` and `acquisitionUsdcBudget` at lines 1173 and 1174, booking a future USDC obligation that is not an already funded reserve, as its own documentation states. `isUsdcSolvent` counts the full `usdcRewardBudgetReserved` on the obligation side but does not subtract `acquisitionUsdcBudget`, while `availableUsdcRewardCapacity` at line 1369 does net it out. As a result `isUsdcSolvent` returns false for any deployment that uses acquisition pools with reward limits, even in a fully healthy state.

IMPACT

View only. `isUsdcSolvent` has no on-chain callers and gates no state change, so there is no fund-loss or liveness risk; this is why the severity is Low rather than Medium. The effect is a persistently incorrect public solvency signal that off-chain monitoring and integrators may rely on, a false insolvency alarm that could prompt misplaced concern or, over time, condition observers to ignore a real insolvency event.

RECOMMENDATION

Subtract `acquisitionUsdcBudget` from the obligation side of `isUsdcSolvent`, mirroring `availableUsdcRewardCapacity`, and factor the shared obligation computation into one internal helper used by both views to prevent future drift.

EVIDENCE

`SokenAuditPoC_.t.sol::testL005_IsUsdcSolventFalseAfterAcquisitionRewardLimit` sets the staking USDC balance to zero, calls `addAcquisitionRewardLimit` for 1,000e6, and shows `isUsdcSolvent` returns false while `availableUsdcRewardCapacity` correctly returns zero. The test passes.

Informational

I-001 Storage layout is append-only and upgrade compatible

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol`	Upgrade safety

DESCRIPTION

A storage layout comparison against `ArvoStakingBaseline` confirms an append-only extension. Slots 0 to 17 are identical. Slots 18 to 26 hold the new oracle, product and acquisition fields. No slot is reordered, retyped or removed.

IMPACT

None. The upgrade path is layout-safe.

RECOMMENDATION

No change required.

I-002 Non-upgradeable reentrancy guard depends on cancun transient storage

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:12`	Upgrade safety

DESCRIPTION

`ArvoStaking`, an upgradeable UUPS contract, imports `ReentrancyGuard` from the non-upgradeable library rather than `ReentrancyGuardUpgradeable`. Under the cancun target this guard uses transient storage, so `_status` holds no storage slot and does not appear in the layout. On a chain without cancun the guard would fall back to regular storage and could conflict with the layout on upgrade.

IMPACT

None given the cancun target. It creates an implicit dependency on the EVM version.

RECOMMENDATION

Document the cancun dependency, or switch to `ReentrancyGuardUpgradeable` for chain-agnostic safety.

I-003 Governance scripts implement a correct two-stage handoff

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Governance scripts	`script/StageArvoGovernance.s.sol`, `script/FinalizeArvoGovernance.s.sol`	Access control

DESCRIPTION

The two-stage governance handoff works as intended. Stage one deploys the timelock, grants `DEFAULT_ADMIN_ROLE` and `UPGRADER_ROLE` to the timelock, `VAULT_MANAGER_ROLE` and `REWARD_MANAGER_ROLE` to the governance Safe and `PAUSER_ROLE` to the emergency authority, and verifies the topology while the deployment account keeps its roles. Stage two verifies stage one, renounces every deployment-account role in order and verifies zero residual privilege. The timelock executor role is checked not to be the zero address, so execution is not permissionless.

IMPACT

Positive. The governance topology is secure after the handoff.

RECOMMENDATION

No change required.

I-004 Floating Solidity pragma

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
All files	All source files	Best practice

DESCRIPTION

All contracts declare `pragma solidity ^0.8.24`. For production the pragma should be pinned to the exact compiler version used for testing, 0.8.35, so a different minor version cannot produce different bytecode.

RECOMMENDATION

Pin the pragma to 0.8.35 for production.

I-005 Unused error declarations in `ArvoPoolCreation`

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoPoolCreation	`src/ArvoPoolCreation.sol:23–26`	Code quality

DESCRIPTION

Four errors declared in `ArvoPoolCreation`, `StakeModeDisabled`, `InvalidAmount`, `BelowMinimum` and `RewardModeDisabled`, are never reverted in the library. The staking contract declares its own identical errors.

RECOMMENDATION

Remove the unused error declarations from the library.

I-006 Irreversible acquisition escrow binding

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:1136–1144`	Design

DESCRIPTION

`configureAcquisitionEscrow` reverts once the escrow is set, so it can be called only once. This is a deliberate one-shot design that prevents an escrow-replacement attack. If the deployed escrow has a defect it cannot be replaced without a full contract upgrade, which the timelock delays by at least 24 hours.

RECOMMENDATION

No change required. The irreversibility is a security property.

I-007 Centralization risk mitigated by the timelock and the multisig

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol`	Centralization

DESCRIPTION

Five privileged roles control all administrative functions. After the handoff, `DEFAULT_ADMIN_ROLE` and `UPGRADER_ROLE` sit on the timelock with a 24 hour or longer delay, `VAULT_MANAGER_ROLE` and `REWARD_MANAGER_ROLE` on the governance Safe and `PAUSER_ROLE` on the emergency authority. The reward manager can withdraw surplus, but only assets outside principal and committed rewards, bounded by `availableArvoRewardCapacity` and `availableUsdcRewardCapacity`. No privileged function can reach staker principal or committed rewards.

IMPACT

A residual trust assumption remains: the multisig operators must not be compromised. This is standard for a protocol that is not governed by a DAO.

RECOMMENDATION

Maintain the operational security of the multisig.

I-008 The user position array grows without bound

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:385, :832`	Gas

DESCRIPTION

The `_userPositionIds` array is append-only; settled positions are never removed, so for a staker who restakes or compounds repeatedly it grows without bound, and the `userPositionIds` view returns the whole array. No on-chain function iterates the array, so there is no protocol-level denial of service.

IMPACT

An increasing gas cost for off-chain view calls. No on-chain impact.

RECOMMENDATION

Add pagination, an offset and a limit, to the view function.

I-009 The static analysis locks-Ether flag is a false positive

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol:26`	Static analysis

DESCRIPTION

A static analysis detector flags `ArvoStaking` as locking Ether without a withdrawal function. The contract has no payable function, no `receive` and no `fallback`; the flag is triggered by the UUPS inheritance. Ether sent to the implementation through a self-destruct is irrelevant to protocol operation and is not staker funds.

IMPACT

None. The flag is a false positive.

RECOMMENDATION

No change required.

I-010 Implementation runtime sits 140 bytes below the EIP-170 limit

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
ArvoStaking	`src/ArvoStaking.sol`	Upgrade safety

DESCRIPTION

The offline build reports the staking implementation runtime at 24,436 of the 24,576 byte EIP-170 limit, leaving 140 bytes of headroom, already with an aggressive optimizer configuration of `optimizer_runs` set to 1 and custom yul steps. A prior testnet build reached 45,553 bytes, which indicates rapid growth.

IMPACT

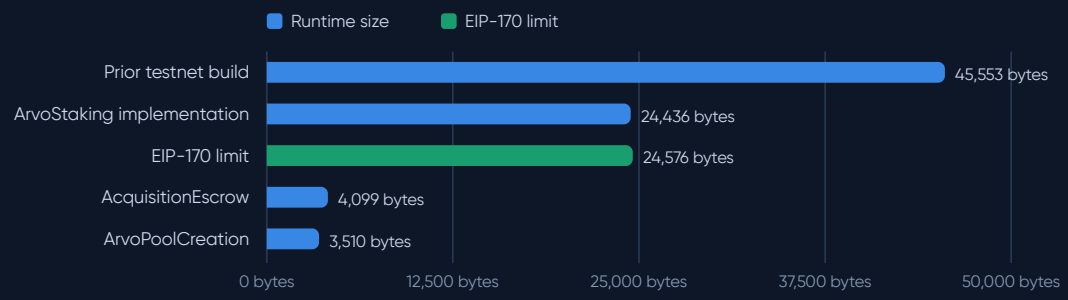
A future UUPS upgrade that adds non-trivial logic will cross 24,576 bytes and fail to deploy unless the optimizer is retuned or logic is split into a library or a second contract. This constrains upgrade flexibility, including shipping the fixes for M-001 and L-005.

RECOMMENDATION

Measure the runtime size in continuous integration, where a size test already exists, and extract view and accounting helpers into a library to reclaim headroom before the next feature upgrade.

EVIDENCE

Figure 4. Runtime size of the deployed code against the EIP-170 limit



Measured offline from the build of `ca8b3d2`. The staking implementation sits 140 bytes under the limit; the prior testnet build was above it.

I-011 Live testnet holds all five roles on a single externally owned account

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Deployment	Robinhood testnet 46630, proxy `0x54697F1BE0E26d079CEb97992df54b8A700C6968`	Centralization

DESCRIPTION

An on-chain read on 2026-10-15 shows `DEFAULT_ADMIN_ROLE`, `UPGRADER_ROLE`, `VAULT_MANAGER_ROLE`, `REWARD_MANAGER_ROLE` and `PAUSER_ROLE` all held by the deployer EOA `0x8A382ca8...96C1477`, which has no code. All roles were granted in the creation transaction and none were revoked. The two-stage handoff reviewed in I-003 and I-007 has not run on this deployment.

IMPACT

On the current deployment one externally owned key can upgrade the implementation, move reward budgets, create pools, and pause or unpause with no delay. The centralization mitigations credited in I-007 depend on running the handoff. For a pre-launch testnet this is expected and it is a prerequisite before a value-bearing deployment.

RECOMMENDATION

Execute the handoff, assigning the roles to the timelock, the governance multisig and the emergency authority, then confirm zero residual deployer privilege on chain before mainnet.

I-012 Offline auth test suite needs dependencies and a fixture to run

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Application	`arvo-app tooling/audit_auth_checks.cjs`	Testing

DESCRIPTION

The repository ships an offline auth test script that exercises the admin challenge and nonce, signature verification, session handling and cross-origin rejection across thirteen scenarios. Running it needs the installed dependencies (TypeScript, viem, Prisma) and a prepared SQLite fixture, which were not present, so the script was not executed. The scenarios were confirmed by reading the source instead.

IMPACT

No fund-safety impact. The coverage exists; it is not wired into a pipeline that would catch an auth regression.

RECOMMENDATION

Wire the fixture preparation and this script into continuous integration so the admin auth path is checked on every change, and ship the fixture helper for reproducibility.

I-013 Admin login challenge uses a custom message format rather than EIP-4361

INFORMATIONAL

COMPONENT	LOCATION	CATEGORY
Application	`arvo-app src/lib/admin/challenge.ts`	Standards

DESCRIPTION

The admin login challenge is a plain-text message carrying the domain, URI, wallet address, nonce and timestamps in a custom layout. The end-user wallet session already uses EIP-4361 (Sign-In with Ethereum) through viem. The admin message holds every security-relevant field but does not follow the structured EIP-4361 form. Admin access is bound to a single configured address, so an attacker needs that exact key regardless of the message shape.

IMPACT

No fund-safety impact. The structured format mainly aids wallet prompt clarity; the single-address admin model makes the difference theoretical here.

RECOMMENDATION

Optionally move admin auth to EIP-4361 for consistency with the user session. Low priority given the single-address constraint.

06 Code at commit 007754e6

FINDINGS AGAINST THE CODE AT 007754E6

FINDING	SEVERITY	AT 007754E6
M-001	MEDIUM	`emergencyExit` routes an acquisition DUAL position through `_settleCashPosition(id, true)`: the ARVO principal is transferred before any escrow call, the USDC leg is recorded in `pendingEmergencyUsdc` and collected through `claimEmergencyUsdc`, owner-checked, pool-isolated, state cleared before the transfer. Three regression tests in the suite and sixteen adversarial tests pass: no double claim, no claim by a non-owner, no payment from the cash of another pool
L-001	LOW	`crossReward` applies one final floor over a wide intermediate product; a fuzz test matches a single division
L-002	LOW	`ArvoPoolCreation` reverts with `InvalidConfiguration` when `minArvo` or `minUsdc` is zero for an enabled mode
L-003	LOW	`Configured`, `Deposited`, `Settled` and `Finalized` events, pool and owner indexed, in the escrow source. The escrow bound to the testnet proxy, `0x8Da5adC0...0bD0B`, is immutable and carries the `ca8b3d2` bytecode without events
L-004	LOW	Pause by the emergency authority is immediate; unpause runs through the timelock; claims stay open during a pause
L-005	LOW	`isUsdcSolvent` counts only the cash-backed budget through `_cashBackedUsdcRewardBudget`; `availableUsdcRewardCapacity` uses `_ordinaryUsdcObligations`. A real shortfall reports false
I-001	INFORMATIONAL	Storage slots 0 to 26 identical to the `ca8b3d2` layout; slot 27 `pendingEmergencyUsdc` appended. The upgrade-safety test passes against the live layout
I-002 to I-009	INFORMATIONAL	Cancun target; pragmas pinned to 0.8.35; the four error declarations are used by the pure validators; one-shot escrow binding; append-only position identifiers; the locks-Ether flag is a false positive
I-010	INFORMATIONAL	Validation, reward and finalization logic in the linked `ArvoPoolCreation` library, 6,389 bytes. The staking runtime is 24,523 bytes, 53 bytes under the EIP-170 limit
I-011	INFORMATIONAL	At block 140,005,118 the deployer holds none of the five roles; the transaction table and the role matrix are below
I-012, I-013	INFORMATIONAL	The application repository runs its auth checks in CI; the admin challenge keeps its own message format

REPOSITORY	COMMIT OF THE FINDINGS	COMMIT OF THIS SECTION	BRANCH
arvo-contracts	`ca8b3d2`	`007754e6`	`audit-remediation-20261019-085800`
arvo-app	`e6ab45a`	`9e9ce9b`	`audit-remediation-20261019-085800`

TESTS AT `007754E6`

RUN	RESULT
Full tracked suite, clean build	271 passed, 0 failed, 0 skipped, 30 suites
Invariant campaigns `invariant_usdcAlwaysSolvent` and `invariant_solvencyViewsRemainTrue`	512 runs by 100 depth each, 51,200 calls each, 0 reverts
Invariant campaigns at 2,000 runs by 100 depth	`invariant_arvoAlwaysSolvent`, `invariant_usdcAlwaysSolvent` and `invariant_solvencyViewsRemainTrue`, 200,000 calls each, 0 reverts, 0 discards
Proof tests written against `ca8b3d2` for M-001 and L-005	Both fail at `007754e6`: the emergency exit succeeds, the solvency view reports true
Adversarial tests on the emergency exit path	16 passed, 0 failed
Public ABI against `ca8b3d2`	No function, event or error removed, no mutability changed; added `claimEmergencyUsdc(uint256)`, `pendingEmergencyUsdc(uint256)`, `EmergencyUsdcDeferred` and `EmergencyUsdcClaimed`
Deployed implementation against the build of `007754e6`	Runtime equal byte for byte except the linked library address `0xc37b305e...7a08e` at twelve link sites and the UUPS self-address immutable at two sites. The trailing metadata hash is identical. Zero unexplained bytes

GOVERNANCE TRANSACTIONS ON CHAIN

ROLE	DEPLOYER	SAFE	TIMELOCK	EMERGENCY AUTHORITY
DEFAULT_ADMIN_ROLE	no	no	yes	no
UPGRADER_ROLE	no	no	yes	no
VAULT_MANAGER_ROLE	no	yes	no	no
REWARD_MANAGER_ROLE	no	yes	no	no
PAUSER_ROLE	no	no	no	yes

`hasRole` read at block 140,005,118 on 2026-10-21 for each of the four accounts. The event replay since the creation block gives the same matrix.

STEP	BLOCK	TIME (UTC)	TRANSACTION
Timelock deployed with a 24 hour delay; the Safe granted proposer, executor and canceller	138,694,193	2026-10-19 11:32:49	`0x4a234e38...416d7`
`DEFAULT_ADMIN_ROLE` and `UPGRADER_ROLE` granted to the timelock	138,694,212 and 138,694,232	2026-10-19 11:32:52	`0xf89c67ed...8ed9d`, `0x0e689ba9...df022`
`VAULT_MANAGER_ROLE` and `REWARD_MANAGER_ROLE` granted to the Safe	138,694,252 and 138,694,273	2026-10-19 11:32:57	`0x5bcf5020...76c9a`, `0x655c90ae...7179f`
`PAUSER_ROLE` granted to the emergency authority	138,694,295	2026-10-19 11:33:02	`0x5bd56b26...50fcf`
Two roles of the externally owned account `0x8d2fba76...ae5bb` revoked	138,704,634 and 138,704,708	2026-10-19 11:56:10	`0xe8d2e645...e1ed2`, `0xf4c9e9e1...5466f`
Operation scheduled by the Safe on the timelock, 86,400 second delay	138,738,729	2026-10-19 13:11:01	`0xfbc3e66e...3ad6a`
Operation executed by the Safe after the delay: `grantRole(UPGRADER_ROLE, timelock)`, a role the timelock holds since block 138,694,232, state unchanged	139,452,439	2026-10-20 13:43:32	`0x4063b5e0...6e04b`
`PAUSER_ROLE`, `VAULT_MANAGER_ROLE`, `REWARD_MANAGER_ROLE` and `UPGRADER_ROLE` renounced by the deployer	139,470,027 to 139,470,556	2026-10-20 14:19:27 to 14:20:33	`0x5782529a...d77a5`, `0x09d03779...b4282`, `0x121e2a35...2c93d`, `0x3fa04cd6...1f43d`
`DEFAULT_ADMIN_ROLE` renounced by the deployer, last	139,470,716	2026-10-20 14:20:52	`0x2a9c2798...1628c`

07 Deployment verification

COMPONENT	ADDRESS ON CHAIN
Proxy (ArvoStaking, EIP-1967)	`0x54697F1BE0E26d079CEb97992df54b8A700C6968`
Implementation	`0x9a81b162d216220118adbb7a444cb26c67b7dff9`
Acquisition escrow	`0x8Da5adC09050992A9AFD35C3d23f69947D10bD0B`
ArvoPoolCreation library	`0xc37b305e4cad49f9261ea4f4eb4d40df2a77a08e`
Timelock	`0x4bfd52101d1ff4647477d1a48a9b9b0e9c74ed22`
Governance Safe	`0xc2Ba67d2A9A6E3dB6e54c58B1de62f33E11F5d7C`
ARVO token	`0xD05e38a43FA819945a4082764562B91d6047b76c`
USDC token	`0xD6554EB0B9fBCb8d8f423Ad4Bf842D473bE6d6B2`

CONTRACT	RUNTIME BYTES	EIP-170 LIMIT	HEADROOM
ArvoStaking implementation, build of `007754e6`	24,523	24,576	53
ArvoAcquisitionEscrow, deployed, build of `ca8b3d2`	4,099	24,576	20,477
ArvoAcquisitionEscrow, build of `007754e6`, not deployed	4,335	24,576	20,241
ArvoPoolCreation, build of `007754e6`	6,389	24,576	18,187

CHECK	RESULT
Runtime size	The build of `007754e6` produces the staking implementation and library runtimes above; the staking implementation sits 53 bytes under the EIP-170 limit. The deployed escrow is the `ca8b3d2` build, 4,099 bytes; the `007754e6` escrow source, with the lifecycle events, builds to 4,335 bytes and is not deployed
Public ABI	The public ABI of `ca8b3d2` is contained in `007754e6`; two functions and two events are added for the deferred USDC claim
Storage layout	Append-only against the `ca8b3d2` layout. Slots 0 to 26 are identical; slot 27 `pendingEmergencyUsdc` is appended. No slot is reordered, retyped or removed
Upgrade path	UUPS. `_authorizeUpgrade` is gated by the upgrader role, held by the timelock. The reentrancy guard uses transient storage under the cancun target and holds no storage slot
Governance topology	The five roles sit on the timelock, the governance Safe and the emergency authority; the deployer holds none. The timelock executor role is held by the Safe only; the zero address holds no timelock role
Implementation slot	The EIP-1967 implementation slot of the proxy holds `0x9a81b162...7dff9`, the build of `007754e6`. The proxy admin slot is zero, correct for UUPS. The implementation and library runtime sizes on chain, 24,523 and 6,389 bytes, equal the build of `007754e6`; the escrow, 4,099 bytes, equals the build of `ca8b3d2` (read 2026-10-21, block 140,005,118)
Deployed bytecode	The deployed implementation runtime equals the `007754e6` runtime except for the UUPS self-address immutable at two sites and the linked `ArvoPoolCreation` address `0xc37b305e...7a08e` at twelve link sites. The trailing metadata hash is identical. Zero unexplained bytes. Both carry the compiler tag solc 0.8.35
Live bindings	`acquisitionEscrow` equals the deployed escrow, `escrow.controller` equals the proxy, `escrow.usdc` equals `proxy.usdc`, and `escrow.totalCash` is zero. The price oracle is the zero address and `maxPriceAge` is zero, so the cross-asset path is inactive on this deployment. `paused()` is false (read 2026-10-21)
Live role holders	Timelock `0x4bfd5210...4ed22`: `DEFAULT_ADMIN_ROLE`, `UPGRADER_ROLE`. Safe `0xc2Ba67d2...F5d7C`, 2 of 2: `VAULT_MANAGER_ROLE`, `REWARD_MANAGER_ROLE`. Emergency authority `0x64B5366B...b2f58`: `PAUSER_ROLE`. Deployer `0x8A382ca8...C1477`: no role (read 2026-10-21, block 140,005,118)

08 Testing

RUN	TESTS	PASSED	FAILED
Full suite, clean build	253	253	0
Invariant campaigns, 3 baseline and 10 added	13	13	0
Proof-of-concept tests for M-001 and L-005	2	2	0

TOPIC	OBSERVATION
Invariant depth	The thirteen invariant campaigns ran for 2,600,000 calls with zero violations. They cover principal and reward liability against the sum of open positions, single-pool budget consistency, solvency after withdrawals, and acquisition escrow cash and principal accounting
Functional coverage	Entry points reachable from at least one test: the staking core 35 of 36 public and external functions, the acquisition escrow 8 of 8, the pool-creation library 2 of 2, the defaults library 4 of 4. The one path not reached is the MIXED reward mode
Coverage method	Line and branch percentages are not reported. The instrumentation for them needs via_ir disabled, and the staking core then aborts on stack-too-deep. Coverage is stated as the functional reachability above
Invariant solvency view	The acquisition solvency invariant excludes `acquisitionUsdcBudget` from the obligation side, matching `availableUsdcRewardCapacity`, because acquisition reward limits are future treasury-funded obligations and are not pre-deposited as cash. The same mismatch in `isUsdcSolvent` is reported as L-005
Test infrastructure gaps	Four upgrade tests need build artifacts from a previous testnet deployment that are absent from the reviewed commit, so they do not run. They are test infrastructure gaps, not contract defects; the one that compares against the 45,553 byte testnet build also records that the prior build exceeded the EIP-170 limit

09 Review coverage

AREA	CHECKED	RESULT
Accounting and solvency	Reward against principal segregation; surplus withdrawal bounded by free capacity; pool reward budget reservation and consumption; no cross-pool leakage	L-005
Staking lifecycle	Stake, claim, emergency exit, restake and compound; reward math at maturity and early exit; double-claim; position ownership; maturity and time handling	M-001
Cross-asset and oracle	ARVO for USDC quote and reward; oracle staleness and decimals; minimum reward slippage guard; zero and negative price	L-001
Acquisition escrow custody	Controller authorization; principal release against repayment; double release; stranded funds; settlement and finalization; project and pool linkage	M-001, L-003
Access control and roles	Every privileged function mapped to its role; pause coverage; over-privilege	L-004, I-007
Upgrade safety	Storage layout against the baseline; initializer protection; UUPS authorization; reentrancy guard storage; runtime size headroom	I-001, I-002, I-010
Governance handoff	Two-stage staging, verification and renouncement; executor role not permissionless	I-003
Pool creation and configuration	Custom and product pool validation; minimum amounts; default parameters; irreversible escrow binding	L-002, I-005, I-006
Reentrancy and token handling	Reentrancy guard on token-moving functions; SafeERC20 and fee-on-transfer exact-amount pulls; unbounded position array	I-008
Static analysis	Slither and Aderyn leads triaged by hand; divide-before-multiply, locks-Ether and reentrancy flags	L-001, I-009
Application fund-safety surface	Transaction construction and signing (viem); treasury and reward-funding controls; admin and wallet authentication (challenge and nonce, signature verification, session issue and revoke, authorization on every admin API route)	I-012, I-013

10 Disclaimer

This report was prepared by SOKEN LTD (Companies House 15253906). It records a security review of the source code at commit ca8b3d2 and of the contracts deployed on Robinhood testnet (46630), dated 21 October 2026. A security review is a point-in-time assessment of the code in scope and is not a guarantee that the code is free of defects, nor an endorsement of the project, its economics or its operators. Statements about on-chain configuration describe the state on the date of reading; on-chain values change, so re-read any figure at the linked address before relying on it. Off-chain key management, operational practice, the front end and third-party protocol risk are outside the scope of this review. Nothing in this document is financial, investment or legal advice.